Homework 1 - Authentication

1. Computing a password hash (see the supplemental help document on computing the **md5** hash).

    a. What is the **md5** hash of the password **GreatPassword**?

    b. If a user's salt is **jc3974** and the password is **GreatPassword**, what is the user's **md5** hash (note the salt is prepended)?

    c. A second user also has the password **GreatPassword**, but this user's salt is **88p3a9** . What is this user's **md5** hash?

    d. Given these results, explain the advantages of adding a salt in password-based authentication systems.

2. Give **two** reasons why **MD5** and **SHA-1** are considered insecure for **password storage**.

3. **Password Combinations**

    a. How many possible passwords are there if passwords can contain **10 or 11** characters chosen from **65** possible characters?

    b. If an attacker can compute 2 million hashes per second, how many **hours** would it take to brute force all possible combinations?

    c. Considering that an attacker will find the passwords without testing all possibilities, what is the **average number of passwords** that would need to be tested and the time required?

4. A password consists of **10 random characters** selected from an alphabet of **94 printable ASCII characters**.

    a. Calculate the **entropy** of this password in bits.

    b. If a user instead chooses a password of **4 random words** from a dictionary of **10,000 words**, what is the entropy?

    c. Which password scheme is stronger?

5. An attacker plans to use a **hash lookup table** that stores pre-computed (password, hash) pairs for **10-million (10,000,000)** passwords. The passwords are exactly 8 characters (i.e., 8-bytes) in length. The SHA-256 hashing algorithm is used, which produces a **256-*bit*** output. How much storage is needed for this table? Give an answer in **bytes**. **Show your work.**

6. The attacker decides to use a **rainbow table** instead of a full lookup table to save disk space. The rainbow table is organized into chains, with each chain containing **5,000** passwords and their corresponding hashes. Given the **10 million** passwords (each 8 characters or **8-bytes** long) and their SHA-256 hashes (**256-bits**) from the previous problem, and assuming each valid password is represented only once, how many chains are needed in the rainbow table if each chain contains 5,000 passwords? **Show your work.**

7. What is the size of this rainbow table? Give an answer in **bytes**. **Show your work.**

8. A rainbow table was created for **unsalted** passwords of length **5** using only **lowercase** letters (a-z) and **digits** (0-9) with an **MD5** hash. Each chain is of length **5**, meaning it contains 5 passwords that were hashed and reduced. In chain creation, a **single reduction function** is applied: the new, reduced password consists of the **last 5 characters of the MD5 hash**. For example,

   The MD5 hash of **abc12** is **b2157e7b2ae716a747597717f1efb7a0**
   The reduction function produces the next password: **fb7a0**

   The rainbow table contains these stored chain values:

Initial Password	MD5 Hash
abcde	455ed9841e757661460ded55bfdb5a11
12345	db4dda44344ed9d9fe95c872318ef4dc
hello	897129298736fb7bbef0123b3f6e0009
world	e84939a184d23f6209ae3babdec14d26
apple	db200fecb77ef1f953d41e5883e08cf9
frog8	9b7d09fa6986200fff61a64892d6446d

You've obtained the following usernames and password hashes from a breach.

Username	MD5 Hash
BartS	c0b33a29a932b715208dcbc227bff4f8
AndyK	9b7d09fa6986200fff61a64892d6446d

Using the rainbow table, find the password for each user. If it does not exist in this rainbow table, state that it is uncrackable. **You must show all of your work.**

a. BartS: **c0b33a29a932b715208dcbc227bff4f8**

b. AndyK: **9b7d09fa6986200fff61a64892d6446d**

9. Another rainbow table was created for **unsalted** passwords of length **5** using only **lowercase** letters (a-z) and **digits** (0-9) with an **MD5** hash. Each chain is of length **4**, meaning it contains 4 passwords that were hashed and reduced. In chain creation, three **reduction functions** are used:

    - **Reduction 1**: use the **last 5 characters of the MD5 hash**.

      For example, if the md5 hash is **b2157e7b2ae716a747597717f1efb7a0**
      The reduction function produces the next password: **fb7a0**

    - **Reduction 2**: use the **first 5 characters of the MD5 hash**.

      For example, if the md5 hash is **b2157e7b2ae716a747597717f1efb7a0**
      The reduction function produces the next password: **b2157**

    - **Reduction 3:** use the **first 3 characters and last 2 characters of the MD5 hash**.

      For example, if the md5 hash is **b2157e7b2ae716a747597717f1efb7a0**
      The reduction function produces the next password: **b21a0**

    The rainbow table contains these stored chain values:

Initial Password	MD5 Hash
abcde	9de0f8a8f8df41463844edef56b470fe
12345	4995996b3bd0cdb9ef145addbb241216
hello	75481e00bee9b53c1c487e2844d76840

    You've obtained the following username and password hash from a breach.

Username	MD5 Hash
JohnD	d65782494389c9666b103c5d378d4d9c

    Using the rainbow table, find the password for the user. If it does not exist in this rainbow table, state that it is uncrackable. **You must show all of your work.**